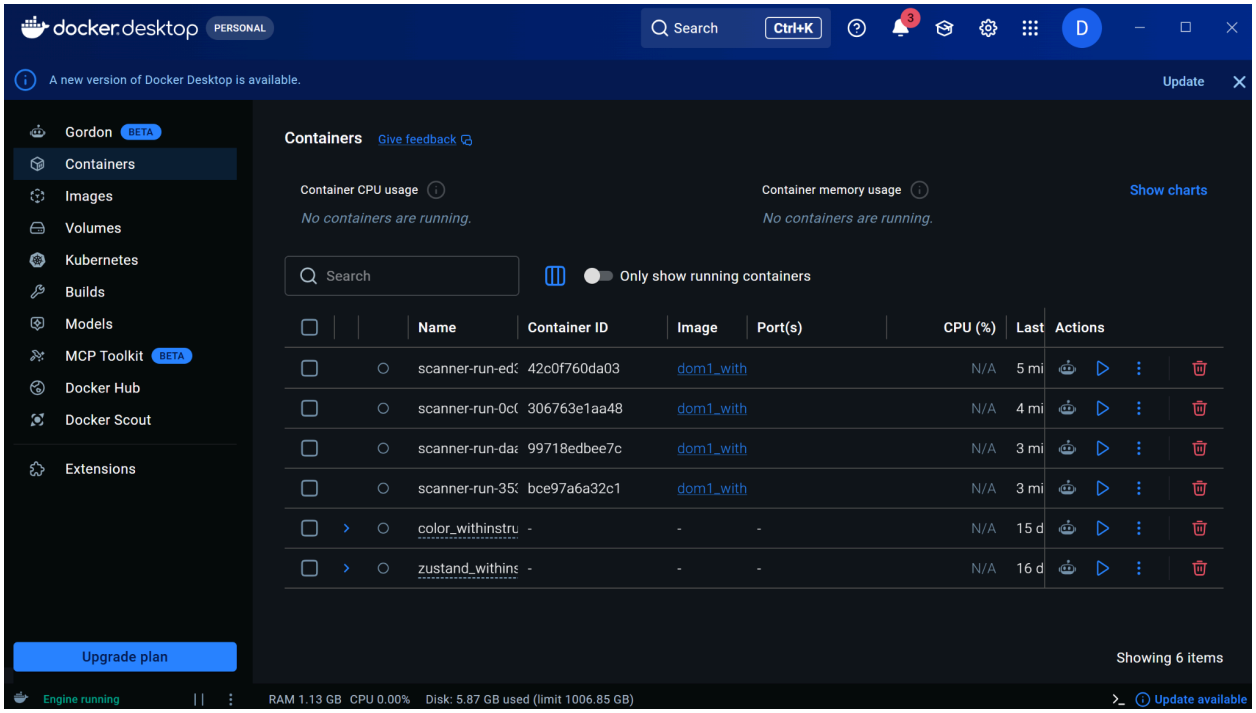
These instructions are just the steps I used to set up the Docker environment myself. If there are any mistakes, please correct me and @mention me! (This does not include the CodeQL setup.)

1. Download the docker desktop and run it



2. File creating

Can be copied to use directly:

Name	Usage
.semgrep.yml	#used to check vulnerabilities, free to add more vulnerabilities for test
scan-vulnerabilities.ps1	#- PowerShell Vulnerability Scanning Script - Integrates Semgrep + Pattern Matching - Outputs JSON Reports
Dockerfile.scanner	#- Docker Image Definition - Includes Semgrep, Bandit, and pip-audit - Non-root User Isolation

A little bit change:

docker-compose.yml	#use docker-compose.template.yml and make some changes

```yaml
# 1. Project name
x-common-env:
  PROJECT_NAME: "my-project"  # ← Change this

# 2. Ports (avoid conflicts)
frontend:
  ports: ["8081:3000"]  # ← Change host port (8080 → 8081, 8082...)

backend:
  ports: ["8001:5000"]  # ← Change host port (8000 → 8001, 8002...)
```

Usage:
```bash
# Copy and rename
cp docker-compose.template.yml new-project/docker-compose.yml
# Then manually update PROJECT_NAME and ports
```

Or automate:
```powershell
.\setup-new-project.ps1 -ProjectName "project2" -BackendPort 8001
-FrontendPort 8081
```

Can not be used and need to be created by yourself or AI agent

Backend Dockerfile
File: `Dockerfile.backend`
- References specific `src/api/vulnerableServer.js`
- AI generates different content
- Different for each project

Frontend Dockerfile
File: `Dockerfile.frontend`
- References specific `src/web/` path
- AI generates different frontend code
- Different for each project

3. Run codes

Build:
docker-compose build

Up:
docker-compose up -d backend frontend

Verify:
curl http://localhost:8000/api/health

Security demo
docker-compose exec backend whoami # ✅ appuser (not root)
docker stats --no-stream # ✅ 512MB limit
docker-compose exec backend sh # ✅ in container
> touch /etc/test.txt # ❌ Read-only file system
> touch /tmp/test.txt # ✅ /tmp can be written
> exit

Scan:
docker-compose run scanner

Down:
docker-compose down

Overall structure After setting environment for Docker

```
Generated project structure:
```
project_2/
├── .semgrep.yml   (✅ Reused)
├── scan-vulnerabilities.ps1 (✅ Reused)
├── Dockerfile.scanner   (✅ Reused)
├── docker-compose.yml   (✅ Configured)
├── Dockerfile.backend   (❌ AI generates)
├── Dockerfile.frontend   (❌ AI generates)
├── .env   (✅ Created)
├── QUICKSTART.md   (✅ Created)
├── src/
│   ├── api/   (❌ AI generates)
│   └── web/   (❌ AI generates)
└── scan-results/   (✅ Created, waiting for results)
```
```